

Incident Response Policy

Table of contents

1. Purpose and scope	2
2. Policy statements	3
3. Controls and procedures	3
3.1 Security Incident Response Team (SIRT)	3
3.2 Incident management process	4
3.3 Phase I — Identification and Triage	6
3.4 Phase II — Containment	7
3.5 Phase III — Eradication	7
3.6 Phase IV — Recovery	8
3.7 Phase V — Post-Incident Analysis	9
3.8 Periodic evaluation and testing	9
4. Incident categories and playbooks	10
4.1 Categories	10
4.2 Severity	11
4.3 Response procedures by category	11
4.4 Special cases	12
5. Emergency operations mode	13
6. Tabletop and red-team exercise	13
7. Incident tracking and records	13

Title	Incident Response Policy
Doc#	POL-SECU-010
Version	2.2
Date	14-03-2025
Supersedes	POL-SECU-010 v2.1 (28-02-2024)
Next Review	14-03-2026
Owner	Isabella Ferreira, Chief Information Security Officer
Approved By	Henrik Larsson, Chief Executive Officer
ISO/IEC 27001:2022	Annex A.5.24–A.5.28 — Information security incident management

This policy is read alongside the Data Breach Notification Policy (POL-BREACH-001), the Access Control Policy (POL-SECU-021), the Change Management Policy (POL-CHANGE-001) and the Business Continuity and Disaster Recovery (BCDR) policy.¹ Where an incident is suspected to involve personal information, the **NDB Playbook (SOP-PRIV-001)** governs the notification workflow and takes precedence over the general steps below.

1. Purpose and scope

This policy sets out how Tessera prepares for, detects, responds to and learns from information security incidents across its managed-cloud platform and corporate environment. The objective is plain: catch incidents early, limit harm to tenants and to Tessera, restore normal operation, meet our notification obligations under the *Privacy Act 1988* (Cth) and the Notifiable Data Breaches (NDB) scheme, and feed what we learn back into the controls. This policy is the primary control satisfying Annex A.5.24–A.5.28 of ISO/IEC 27001:2022 and operates alongside the ASD Essential Eight mitigations, particularly the application control, patching, and daily-backup and recovery strategies that an incident may invoke.

It applies to all Tessera staff, contractors and third parties acting on Tessera’s behalf, and to all systems and environments that process, store or transit Tessera or tenant data — including the multi-tenant production platform hosted primarily in AWS **ap-southeast-2** (Sydney) with cross-region standby, the corporate network, and SaaS services in tenant or internal use.

The policy covers information security incidents only. Physical security incidents — site access, theft of hardware, tailgating — are handled under the Physical and Environmental Security Policy (POL-PHYS-001).

[Reviewer, 2025-03-06: POL-PHYS-001 was last reviewed in mid-2022 and is on the overdue list. Confirm it’s still current before relying on it for incident hand-off.]

The incident response process addresses, at minimum:

- continuous monitoring of threats through the SIEM and security tooling;
- a standing Security Incident Response Team (SIRT) with defined authority;
- clear procedures for identifying, triaging, containing, eradicating and recovering from incidents;
- notification of tenants, regulators and individuals as required;
- workforce training and awareness of reporting and response duties; and
- post-incident review so that each event improves the next response.

¹Formerly numbered POL-BC-001; reissued as POL-BCDR-001 during the 2024 risk-document consolidation. Some older runbooks still cite the old number.

2. Policy statements

Tessera requires that:

- (a) All production and corporate environments are monitored in accordance with the Tessera Logging and Monitoring standard and the policies referenced there — principally the Access Control Policy (POL-SECU-021), the Acceptable Use Policy (POL-SEC-022) and the System Auditing Policy (POL-AUDIT-001).

[I. Ferreira, note to self: align the referenced policy set with ISMS-PR-014 wording before the Stage 1 audit — the SoA (DOC-SEC-003) references a slightly different list.]

- (b) All security-relevant alerts are reviewed by a qualified analyst and triaged against the severity matrix in this policy.
- (c) Incident response procedures are invoked as soon as a valid security incident is confirmed.
- (d) Where an incident may involve a notifiable data breach, the SIRT and the Head of Compliance assess eligibility under the NDB scheme without delay and, where eligible, notify the Office of the Australian Information Commissioner (OAIC) as soon as practicable and within Tessera’s internal **72-hour** target. Affected individuals are notified as required by Part IIIC of the Privacy Act.
- (e) The SIRT and management comply with lawful requests from Australian law enforcement and national-security agencies — including the Australian Federal Police (AFP), state or territory police, and the Australian Cyber Security Centre (ACSC) — in the event of a criminal investigation or national-security matter, acting only on properly issued warrants, court orders or lawful compulsory process.

3. Controls and procedures

3.1 Security Incident Response Team (SIRT)

The SIRT is the standing body that owns incident response end to end. It is responsible for:

- logging, tracking and reviewing all reports and their status in the Security Incident Register (DOC-SEC-005);
- investigating incidents and executing containment, eradication and recovery plans;
- coordinating tenant, regulator and individual notifications;
- engaging and directing external forensic or legal support where needed; and
- liaising with law enforcement and the ACSC where appropriate.

The SIRT is led by the CISO and convened as follows:

Role	Member
Incident lead / chair	Isabella Ferreira , CISO
Head of Engineering	Noah Bennett
Head of IT	Hamish Boyd
Cloud Service Operations	Rafa Costa
On-call security engineer	Security Engineering rotation
On-call platform engineer	Platform Engineering rotation

The Head of Compliance (Margaux Dubois) and Head of People (Anika Desai) are co-opted for incidents involving privacy, breach notification or workforce conduct.

[Reviewer, 2025-03-10: the on-call rotation above reflects the roster as at 1 March 2025. The PagerDuty schedule is the source of truth for current on-call names — reconcile before an actual page.]

The 24×7 contact path is the PagerDuty **sec-oncall** escalation policy, which pages the on-call security engineer and, if unacknowledged, escalates to the CISO within 15 minutes. After-hours incidents reported by email or chat must be escalated to PagerDuty by the first responder — email and chat are not themselves monitored out of hours.

3.2 Incident management process

The response process follows the six-phase SANS lifecycle — Identification and Triage, Containment, Eradication, Recovery, Post-Incident Analysis, and ongoing Preparation — adapted to Tessera’s environment. A flowchart of the end-to-end process is maintained alongside this policy.

[Reviewer, 2025-02-28: the flowchart was relocated during the documentation migration and now lives at `docs/runbooks/ir-flowchart.qmd`. The legacy `sections/incident-flowchart.pdf` path still referenced from some older tickets returns a 404 — update those links.]

Tessera classifies security-relevant observations into four kinds:

- **Events** — an observable occurrence in a system or network that is investigated for security relevance but is not, on its own, a confirmed incident. Most events turn out to be operational (a failed disk, a deploy that tripped an alert) and are routed to the owning team rather than the SIRT.
- **Precursors** — a sign that an incident *may* occur. Examples: a monitoring system flagging anomalous behaviour, repeated failed sign-ins to the IdP, or suspicious email targeting staff with privileged production access. Precursor signals arrive from the security tooling Tessera has in production, including:

- **Auth0** — identity and authentication activity;
- **Splunk** — correlated SIEM events across log sources;
- **Prisma Cloud** — cloud configuration and posture alerts;
- **Carbon Black Cloud** — endpoint, malware and EDR events;
- **AWS GuardDuty, CloudTrail and Security Hub** — control-plane and threat-detection signals from the production AWS accounts; and
- Syslog from servers and network devices.

[Reviewer, 2025-03-04: the line above was rewritten when we migrated the IdP, but the December 2023 SOC 2 description still names Okta in a couple of places. Leave for now; clean up at the next SOC 2 refresh.]

- **Indications** — a sign that an incident *may have occurred or be occurring now*. Examples: alerts for modified system files or unexpected privileged access, EDR alerts for a compromised endpoint, or anomalous egress to an unfamiliar destination.
- **Incidents** — a confirmed indicator of compromise or a validated breach of policy, often involving exposure of data. Examples: unauthorised disclosure or destruction of tenant data, a successful account takeover, a confirmed data breach by an internal or external actor, or a denial-of-service attack that takes a critical service offline.

Every workforce member is responsible for reporting anything in the categories above that they observe on production systems or in associated communications (email, chat, code repositories). In practice this means: if something looks wrong, raise it — do not wait for certainty.

Reports are made through any of:

- security@tessera.locoensayo.org;
- the **#sec-incidents** channel;
- the PagerDuty **sec-oncall** escalation (for suspected active incidents, in or out of hours); or
- the Tessera Internal ServiceDesk incident form.

[Reviewer, 2025-03-05: the ServiceDesk incident form was retired when we moved to the new support portal — the link target above was never updated. Use the portal until this is fixed.]

!!! attention

Any incident with a severity above ****MINOR**** triggers the full response process below, and any incident that may involve personal information additionally triggers the NDB Playbook (SOP-PRIV-001).

3.3 Phase I — Identification and Triage

1. On observing a suspected event, precursor, indication or incident, the reporter raises it through one of the channels above, including what they saw, when, and any systems or tenants they believe are affected.
2. The on-call security engineer (the “first responder”) acknowledges the report, gathers any additional detail needed, and determines whether the report is an event, precursor, indication or incident.
 1. If it is an event, indication or precursor that is **not** a security incident, the first responder routes it to the owning team and records the disposition in the Security Incident Register (DOC-SEC-005). Non-technical or minor items are logged as a Jira task for follow-up.
 2. If it is a confirmed **security incident**, the first responder pages the SIRT via PagerDuty and notifies the CISO and senior leadership by email within one hour of confirmation.
 1. For a non-technical security incident, the SIRT completes the investigation, implements preventative measures and resolves it.
 2. Once resolved, the SIRT moves to Phase V (Post-Incident Analysis).
 3. For a technical security incident, the SIRT moves to Phase II (Containment).
 4. The Containment, Eradication and Recovery phases are technical and are executed by qualified security engineers with SIRT oversight.
 5. Every responder records what they did and the start/end time of each action; contemporaneous notes matter for later review and for any law-enforcement referral.
 6. The incident lead opens an incident ticket in Jira (project **SEC**) and documents findings there as the single source of truth.

[Reviewer, 2025-03-11: the one-hour leadership-notification target is from the Feb 2025 post-mortem of TSR-INC-2025-031 and has not yet been ratified by the Executive Risk Committee — treat as draft until endorsed.]

3. The CISO (or delegate) determines whether tenants or partners are affected and, if so, initiates tenant notification per the contract and the breach policy. If no tenant is affected, notification is at the CISO’s discretion.
4. Where the incident may involve personal information, the CISO and Head of Compliance begin the NDB eligibility assessment immediately and in parallel with containment — do not wait for containment to complete before starting the clock on notification.

3.4 Phase II — Containment

The aim of containment is to stop the incident spreading while preserving evidence. Detailed, timestamped notes are taken throughout so that evidence can support any later prosecution or regulatory action.

1. Review all information collected so far by the first responder and SIRT.
2. Define and secure the blast radius — the logical (or, rarely, physical) perimeter around the affected systems.

[Reviewer, 2025-02-28: chain-of-custody for disk images and memory captures is handled on the chain-of-custody form[^{chain}] in the SIRT runbook. The form number is being reissued — confirm the current reference before relying on it.]

3. As needed, prepare for forensic analysis:
 1. connect to the affected system over a trusted, out-of-band connection;
 2. capture volatile data (memory, network state, running processes) before anything else;
 3. assess the integrity of the system and decide whether to back it up;
 4. take a snapshot or image of the disk for forensic analysis, and back up the system if appropriate;
 5. rotate credentials for the affected systems — application secrets, AWS keys, and IdP (Auth0) sessions for any compromised identity;
 6. decide whether it is safe to keep the affected system running; and
 7. if it is safe, allow it to continue and move to Phase V; if not, take it out of service and move to Phase III.
4. Record all containment actions and timestamps on the incident ticket.
5. Keep senior management informed of progress — at minimum a written update at each phase boundary, and more often for a Critical incident.
6. Continue tenant and partner notifications with material updates as the picture changes.

3.5 Phase III — Eradication

Eradication removes the cause of the incident and the exposure it created.

1. Confirm the root cause and the full set of affected systems — do not assume the first affected host is the only one.
2. Strengthen defences around the affected systems where possible. This may include tightening network segmentation, raising monitoring sensitivity, or host hardening (removing unused services, patching).

3. Run a vulnerability assessment across the affected scope to confirm that the exploited weaknesses — and any related ones — have been closed.

[Reviewer, 2025-03-09: there is no fixed window for the eradication vulnerability scan. In practice it is “as soon as the SIRT can schedule it”; for Critical incidents this has meant same-day, but it is not written down as an SLA. Worth fixing.]

4. Record eradication actions, root cause and remediation method on the incident ticket.
5. Update senior management and affected tenants with relevant changes.
6. Move to Phase IV (Recovery).

3.6 Phase IV — Recovery

Recovery returns affected systems to normal operation and confirms they are clean.

1. Determine whether the affected systems were altered.
 1. If altered, restore from a known-good state (clean snapshot or rebuild), then validate function with the owning engineering team before returning to service.
 2. If the system was taken offline but not altered, restart and monitor.
 3. In either case, monitor the restored system for recurrence before declaring the incident closed.

[Reviewer, 2025-03-09: the post-recovery monitoring window is not specified. Convention is 72 hours of heightened monitoring for Critical and 24 hours for Major, but it is not in this policy.]

2. The business owner of the affected system authorises return to service; the SIRT does not unilaterally return a tenant-facing system to production.

(N. Bennett: in practice the service owner is the Head of Engineering or their delegate; for a tenant-facing service this sign-off is not optional, even mid-incident.)

3. Record recovery actions and the decision to return to service on the ticket.
4. Update senior management and affected tenants.
5. Move to Phase V (Post-Incident Analysis).

3.7 Phase V — Post-Incident Analysis

The post-incident review captures what happened, what it cost, and what to change. It is run for every Major and Critical incident, and for any Minor incident where the SIRT judges there is something to learn.

1. Within ten business days of incident closure, the responders meet to review the timeline and documentation.

[Reviewer, 2025-03-12: “ten business days” replaced an earlier “shortly after resolution / one to two weeks”. The 2025-03 revision standardised on ten business days; older Jira tickets may still carry the old wording.]

2. A lessons-learned write-up is attached to the incident ticket and the Security Incident Register (DOC-SEC-005).

1. Assess the cost and impact to Tessera and affected tenants — response effort, downtime, lost revenue, remediation cost, and any notification or regulatory cost.
2. Identify what to improve: systems and processes, detective controls, awareness training, or additional controls.
3. Record agreed actions as Jira tickets under a tracking epic, with owners and due dates, and report them to the Executive Risk Committee.

[Reviewer, 2025-03-12: the post-incident action epic exists (SECIR in Jira) but is not consistently used for Minor incidents. Tighten up at next review.]

3. Retain all incident records per the Tessera Records Retention Schedule (DOC-REC-001, DRAFT v0.2 — pending Compliance sign-off) and the System Auditing Policy (POL-AUDIT-001).
4. Close the incident in the register.

3.8 Periodic evaluation and testing

The incident response capability is reviewed at least annually and after any significant incident, and is tested through at least one tabletop or simulated exercise per year.

[Reviewer, 2025-03-10: the 2025 exercise schedule is drafted but not yet endorsed by the Executive Risk Committee — see `docs/runbooks/ir-exercise-2025.qmd` (DRAFT v0.3, pending sign-off, M. Dubois).]

Exercises may be run internally or with an external security firm, and range from a two- to four-hour tabletop to a multi-week red-team engagement. The senior leadership team is invited to participate or to receive a readout. Exercise outcomes and any control gaps found are recorded and tracked to closure in the same way as post-incident actions.

4. Incident categories and playbooks

The SIRT reviews security events as part of daily operations. Based on initial analysis, an event may be dismissed (false positive, normal business activity, an approved exception, or a duplicate); a dismissed event is recorded with the reason so the audit trail is preserved. A valid event may be escalated to a security incident, at which point a category and severity are assigned, and the decision — with date and assessor — is recorded in the register.

A containment, eradication and recovery procedure is triggered based on the category. In addition to the general process above, the relevant playbook is consulted.

4.1 Categories

- **Category 1 — General incidents.** Incidents that do not fit a more specific category, including policy violations and lower-impact events. (Physical security events are handled under POL-PHYS-001 and are out of scope here unless they have a cyber component, in which case the SIRT coordinates with facilities.)
- **Category 2 — Attacks on internal infrastructure.** Attacks against corporate or platform network, hardware or software — for example unauthorised access to an internal host or lateral movement.
- **Category 3 — Malware.** Confirmed malicious code on Tessera-managed systems, including endpoints and build infrastructure.
- **Category 4 — Attacks on external-facing assets.** Attacks against Tessera’s public footprint — web applications, APIs and public services — including denial-of-service and distributed denial-of-service (DoS/DDoS).
- **Category 5 — Human-targeted attacks.** Social engineering, phishing, business email compromise and pretexting directed at workforce members.
- **Category 6 — Breach or leakage of data.** Unauthorised access to, disclosure, or exfiltration of Tessera or tenant data. Definitions of data sensitivity follow the Data Classification Policy; any Category 6 incident involving personal information also invokes the NDB Playbook (SOP-PRIV-001).

4.2 Severity

Incidents are assigned a severity that drives response times and escalation. The matrix below is the working standard; the response-time targets in it are endorsed for Major and Critical and remain in draft for Minor.

Severity	Typical trigger	First response	Leadership brief	Containment target
Critical	Significant interruption to operations and/or confirmed or likely breach of confidential or personal data	Immediate (page SIRT)	Within 1 hour	Best-effort continuous
Major	Material interruption to operations, data exposure unlikely	Within 2 hours (business hours)	Within 4 hours	Within 4 hours
Minor	All other confirmed incidents	Next business day	At SIRT discretion	Within 1 business day

[Reviewer, 2025-03-11: the Minor column has not been ratified by the Executive Risk Committee. Treat as draft until endorsed.]

For any incident that may meet the NDB threshold, the OAIC notification target (72 hours from formation of a belief that a notifiable breach has occurred) overrides the containment target — notification runs in parallel with containment, not after it.

4.3 Response procedures by category

Category 1 — General incident. Prioritise by functional and informational impact and by recoverability; report to the appropriate internal and external parties; acquire, preserve and document evidence; contain, eradicate and recover, restoring affected systems and adding preventive measures.

Category 2 — Internal infrastructure. Depending on the event, the relevant playbook is followed for unauthorised access, root or privileged access, elevation of privilege, or improper usage.

Category 3 — Malware. Depending on the agent, the malware or outbreak playbook is followed; Carbon Black Cloud containment (network isolate / ban hash) is the primary technical lever.

Category 4 — External web attack / DoS-DDoS. Engineering is mobilised to protect systems and preserve availability; a thorough investigation is conducted; legal and regulatory obligations are addressed; and, if the incident threatens continuity, the **BCDR trigger is pulled** — escalating to the BCDR policy (POL-BCDR-001) and the Failover Runbook (SOP-BCDR-001).

[Reviewer, 2025-03-12: the criteria for declaring a BCDR event are defined in the BCDR policy, not here. Cross-check the threshold before escalating — earlier drafts of this policy implied any DoS was a BCDR event, which is not the case.]

Category 5 — Social engineering / phishing. The phishing playbook is followed; affected credentials are rotated in Auth0 and any granted sessions revoked.

Category 6 — Data leakage. The data-theft playbook is followed; the NDB Playbook (SOP-PRIV-001) is invoked where personal information is involved.

[Reviewer, 2025-03-10: the category playbooks above currently point at third-party references (incidentresponse.com). They go stale and have broken before. Internalising them as version-controlled runbooks is on the backlog — see ticket #####.]

4.4 Special cases

Healthcare tenants (US PHI). Tessera’s own governing regime is the *Privacy Act 1988* and the NDB scheme, not HIPAA. For tenants that are US healthcare providers or covered entities, a Business Associate Addendum (BAA) is executed and the contractual notification terms in that BAA apply to any incident affecting that tenant’s data. In such a case the affected tenant (the covered entity) carries its own HIPAA notification duties; Tessera’s job is to inform the tenant within the timeframe and by the channel set out in the BAA and the breach policy (POL-BREACH-001; the BAA notification appendix referenced there is still in draft and not yet published).

Criminal activity. Where an incident involves suspected criminal conduct, the CISO, with the CEO and external counsel, determines whether to refer the matter to the **Australian Federal Police**, the relevant **state or territory police**, or to report it to the **Australian Cyber Security Centre (ACSC)** via the ReportCyber portal. Engagement with law enforcement is coordinated through counsel and proceeds only on proper authority.

Insider threat. Insider-threat incidents are handled by a cross-discipline team comprising the CISO (Isabella Ferreira), the Head of People (Anika Desai) and the Head of Engineering (Noah Bennett), with the Head of Compliance (Margaux Dubois) advising. The COO is engaged where operational continuity is at risk.

5. Emergency operations mode

If an incident constitutes an emergency — for example an active compromise of the production management plane — Tessera may move production to a read-only emergency posture. In this mode customers retain read access to their data but all write access and data ingestion are paused until the emergency is resolved. This is effected by updating IAM and access policy in the production AWS accounts.

[Reviewer, 2025-03-09: the threshold for declaring emergency operations mode (“active compromise of the production management plane”) is indicative, not exhaustive — the CISO has discretion. The customer-communication template for a read-only cutover is drafted but not yet approved by Comms; do not rely on it until signed off.]

In emergency operations mode, temporary write or forensic access may be granted to named security and engineering staff to perform forensics, root-cause analysis, eradication and recovery. Such grants are time-boxed, logged, and revoked on exit from emergency mode.

6. Tabletop and red-team exercise

At least once a year the security and engineering teams jointly run a tabletop exercise or a simulated drill of a cyberattack resulting in one or more Critical incidents. Depending on the format, this ranges from a two- to four-hour tabletop to a multi-week red-team engagement. The exercise follows a prepared attack scenario and may be delivered internally or with an external security firm.

The goal is to give responders realistic practice, to test the documented procedures, and to surface gaps before a real event. The senior leadership team is invited to take part or to receive a readout. Exercise findings and the actions they generate are documented and tracked to closure in the same way as post-incident actions.

7. Incident tracking and records

A record is created for each reported incident in Jira and tracked in the Security Incident Register (DOC-SEC-005). Each incident record captures, as applicable:

- summary and description;
- impact and affected tenants;
- priority / urgency and severity;
- category and classification;
- analysis notes and timeline;
- root cause and determination;
- resolution and outcome; and

- lessons learned and agreed actions.

Where a detailed post-mortem is warranted — for any Critical incident, and for Major incidents where the cause is non-obvious — the assigned SIRT engineer writes the post-mortem and links it from the incident record.

[Reviewer, 2025-03-11: the post-mortem threshold (“Major where the cause is non-obvious”) is judgement-based and is applied inconsistently across the team. Consider a harder rule at the next revision.]

This policy is owned by the CISO and approved by the CEO. It is reviewed at least annually and after any significant incident. The next scheduled review is 14-03-2026.